

RISK ASSESSMENT REPORT (RAR)
Small Town Network Simulation
May 13th, 2026

Record of Changes:

Version	Date	Sections Modified	Description of Changes
1.0	13 May 2026	Initial RAR	
1.1	19 May 2026	Controls Implemented	Documented implemented controls to mitigate NIST SP 800-53 non-compliance.

System Description

The Small Town Network Simulation consists of a simulated network topology built in Cisco Packet Tracer processing unclassified data. The risk categorization for this Information System (IS) is assessed as SC = (Confidentiality, Low), (Integrity, Low), (Availability, Low).

IS# STNS-001 is located in a simulated virtual environment hosted on a local workstation using Cisco Packet Tracer. The IS is composed of multiple subnets of interconnected routers, switches, and endpoints connected via a central routing infrastructure. This IS is used to simulate network operations including inter-department communication, internet gateway access, and network security protocols, in support of performance on the cybersecurity portfolio project *Network Security Audit Simulation*. The IS is a static simulated environment with no mobility. All devices on the network are virtualized devices within Cisco Packet Tracer and do not represent physical devices. The simulation is separate from external networks and is entirely isolated within its own local workstation environment.

The Information Owner is Kaushik Venkatesh.

The ISSM is Kaushik Venkatesh.

The ISSO is Kaushik Venkatesh.

Scope

The scope of this risk assessment is focused on the system's use of resources and controls to mitigate vulnerabilities exploitable by threat agents (external) identified during the RMF control selection process, based on the system's categorization.

This initial assessment will be a Tier 3 or "information system level" risk assessment. While not entirely comprehensive of all threats and vulnerabilities to the IS, this assessment will include any known risks related to the incomplete or inadequate implementation of the NIST SP 800-53

controls selected for this system. This document will be updated after certification testing to include any vulnerabilities or observations by the independent assessment team. Data collected during this assessment may be used to support higher level risk assessments at the mission/business or organization level.

The scope of this assessment will be considering strictly external digital threats to the network. No other threats or attack vectors, including but not limited to software exploits, social engineering threats, or physical threats will be discussed. Since the IS being addressed in this assessment is entirely digital and simulated, an attacker in the context of this RAR will be any generic external threat actor that attempts an intrusion or exploitation of the network. Since this simulation is not representative of any other physical network, only this simulated environment will be assessed. Only network-based attack vectors will be discussed, addressing steps of the Cyber Kill Chain framework as necessary to structure the progression of identified threats. All findings of compliance and non-compliance within this assessment are limited to configurations and behaviors observable within the capabilities of Cisco Packet Tracer's simulation environment.

Findings of NIST SP 800-53 Compliance and Non-Compliance

Compliance with applicable NIST SP 800-53 controls was assessed through manual review of the network topology and device configurations within the Cisco Packet Tracer simulation environment. VLAN segmentation and WPA2-PSK wireless security are implemented to ensure NIST SP 800-53 compliance, providing partial satisfaction of SC-2, IA-3, and SC-8. However, these controls are minimal and do not fully satisfy SC-7, SC-5, or SI-4(4), which mandate boundary protection, denial of service prevention, and traffic monitoring respectively.

Instances of non-compliance include:

SC-7 (Boundary Protection)

No firewall or boundary protection is present at network perimeter. As a result, traffic entering and leaving the network is unfiltered and unchecked, allowing for potential malicious connections with internal endpoints and leaving the IS with no managed interface at its boundaries.

SC-7(5)(Deny by Default / Allow by Exception)

Since no firewalls or port filtering is implemented within the IS, all connections are allowed within the network by default. This violates the deny by default principle and leaves the IS vulnerable to unauthorized connections.

SC-7(8)(Route Traffic to Controlled Managed Interfaces)

Due to the lack of boundary protections within the IS, there is no controlled interface that all connections pass through and can be monitored from. This leads to unauthorized connections and introduces the potential for intrusion-based attacks.

SC-5(Denial of Service Protection)

No rate limiting or port filtering is implemented at network perimeter. This allows for Denial of Service (DoS) attacks that can be performed by sending excessive traffic, degrading or completely disrupting network availability.

SI-4 (4)(Inbound and Outbound Communications Traffic)

The absence of traffic monitoring tools fails to limit and monitor inbound and outbound traffic rules. As a result, this allows for unsolicited traffic on the network with a lack of detection capability.

Operating and Physical Security Conditions

The IS runs entirely within the Cisco Packet Tracer simulated environment hosted on a virtual workstation processing unclassified data. The system maintains no connections to outside networks and represents a static, isolated environment. No physical infrastructure exists. Physical security considerations are limited to the local workstation hosting the simulation accessible only to the Information Owner.

Timeframe Supported by the Assessment

This security assessment was conducted on May 13, 2026, and reflects the current state of the Small Town Network Simulation (STNS-001) Information System. As this IS is a static simulated environment with no planned modifications to its topology or configuration except additional security controls, the assessment will remain valid for the duration of the Network Security Audit Simulation portfolio project unless significant changes are made to the simulated network architecture, at which point a revision of this assessment should be conducted.

Purpose

This initial risk assessment was conducted to identify and document the security risks associated with the Small Town Network Simulation (STNS-001) as a part of the Network Security Audit Simulation cybersecurity portfolio project. The assessment was prompted by the need to evaluate the existing architecture of the network against the established NIST SP 800-53 framework and identify areas where the initial implementation of the network simulation might have left residual risk. The findings of this assessment will provide an upfront risk profile of the simulated environment, documenting known gaps and vulnerabilities to ensure the application of network security measures.

Risk Assessment Approach

This initial risk assessment was conducted using the guidelines outlined in the *NIST SP 800-30, Guide for Conducting Risk Assessments*. A qualitative approach will be utilized for this assessment. Risk will be determined based on a threat event, the likelihood of that threat event occurring, known system vulnerabilities, mitigating factors, and consequences/impact to mission.

The following table is provided as a list of sample threat sources. Use this table to determine relevant threats to the system.

Table 1: Sample Threat Sources (see NIST SP 800-30 for complete list)

TYPE OF THREAT SOURCE	DESCRIPTION
ADVERSARIAL - Individual (outsider, insider, trusted, privileged) - Group (ad-hoc or established) - Organization (competitor, supplier, partner, customer) - Nation state	Individuals, groups, organizations, or states that seek to exploit the organization's dependence on cyber resources (e.g., information in electronic form, information and communications, and the communications and information-handling capabilities provided by those technologies).
ADVERSARIAL - Standard user - Privileged user/Administrator	Erroneous actions taken by individuals in the course of executing everyday responsibilities.
STRUCTURAL - IT Equipment (storage, processing, comm., display, sensor, controller) - Environmental conditions • Temperature/humidity controls • Power supply - Software • Operating system • Networking • General-purpose application • Mission-specific application	Failures of equipment, environmental controls, or software due to aging, resource depletion, or other circumstances which exceed expected operating parameters.
ENVIRONMENTAL - Natural or man-made (fire, flood, earthquake, etc.) - Unusual natural event (e.g., sunspots) - Infrastructure failure/outage (electrical, telecomm)	Natural disasters and failures of critical infrastructures on which the organization depends, but is outside the control of the organization. Can be characterized in terms of severity and duration.

The following tables from the NIST SP 800-30 were used to assign values to likelihood, impact, and risk:

Table 2: Assessment Scale – Likelihood of Threat Event Initiation (Adversarial)

Qualitative Values	Semi-Quantitative Values		Description
Very High	96-100	10	Adversary is almost certain to initiate the threat event.
High	80-95	8	Adversary is highly likely to initiate the threat event.

Qualitative Values	Semi-Quantitative Values		Description
Moderate	21-79	5	Adversary is somewhat likely to initiate the threat event.
Low	5-20	2	Adversary is unlikely to initiate the threat event.
Very Low	0-4	0	Adversary is highly unlikely to initiate the threat event

Table 3: Assessment Scale – Likelihood of Threat Event Occurrence (Non-adversarial)

Qualitative Values	Semi-Quantitative Values		Description
Very High	96-100	10	Error, accident, or act of nature is almost certain to occur; or occurs more than 100 times per year .
High	80-95	8	Error, accident, or act of nature is highly likely to occur; or occurs between 10-100 times per year .
Moderate	21-79	5	Error, accident, or act of nature is somewhat likely to occur; or occurs between 1-10 times per year .
Low	5-20	2	Error, accident, or act of nature is unlikely to occur; or occurs less than once a year, but more than once every 10 years .
Very Low	0-4	0	Error, accident, or act of nature is highly unlikely to occur; or occurs less than once every 10 years .

Table 4: Assessment Scale – Impact of Threat Events

Qualitative Values	Semi-Quantitative Values		Description
Very High	96-100	10	The threat event could be expected to have multiple severe or catastrophic adverse effects on organizational operations, organizational assets, individuals, other organizations, or the Nation.
High	80-95	8	The threat event could be expected to have a severe or catastrophic adverse effect on organizational operations, organizational assets, individuals, other organizations, or the Nation. A severe or catastrophic adverse effect means that, for example, the threat event might: (i) cause a severe degradation in or loss of mission capability to an extent and duration that the organization is not able to perform one or more of its primary functions; (ii) result in major damage to organizational assets; (iii) result in major financial loss; or (iv) result in severe or catastrophic harm to individuals involving loss of life or serious life threatening injuries.

Qualitative Values	Semi-Quantitative Values		Description
Moderate	21-79	5	The threat event could be expected to have a serious adverse effect on organizational operations, organizational assets, individuals other organizations, or the Nation. A serious adverse effect means that, for example, the threat event might: (i) cause a significant degradation in mission capability to an extent and duration that the organization is able to perform its primary functions, but the effectiveness of the functions is significantly reduced; (ii) result in significant damage to organizational assets; (iii) result in significant financial loss; or (iv) result in significant harm to individuals that does not involve loss of life or serious life threatening injuries.
Low	5-20	2	The threat event could be expected to have a limited adverse effect on organizational operations, organizational assets, individuals other organizations, or the Nation. A limited adverse effect means that, for example, the threat event might: (i) cause a degradation in mission capability to an extent and duration that the organization is able to perform its primary functions, but the effectiveness of the functions is noticeably reduced; (ii) result in minor damage to organizational assets; (iii) result in minor financial loss; or (iv) result in minor harm to individuals.
Very Low	0-4	0	The threat event could be expected to have a negligible adverse effect on organizational operations, organizational assets, individuals other organizations, or the Nation.

Table 5: Assessment Scale – Level of Risk

Qualitative Values	Semi-Quantitative Values		Description
Very High	96-100	10	Threat event could be expected to have multiple severe or catastrophic adverse effects on organizational operations, organizational assets, individuals, other organizations, or the Nation.
High	80-95	8	Threat event could be expected to have a severe or catastrophic adverse effect on organizational operations, organizational assets, individuals, other organizations, or the Nation.
Moderate	21-79	5	Threat event could be expected to have a serious adverse effect on organizational operations, organizational assets, individuals, other organizations, or the Nation.

Qualitative Values	Semi-Quantitative Values		Description
Low	5-20	2	Threat event could be expected to have a limited adverse effect on organizational operations, organizational assets, individuals, other organizations, or the Nation.
Very Low	0-4	0	Threat event could be expected to have a negligible adverse effect on organizational operations, organizational assets, individuals, other organizations, or the Nation.

Table 6: Assessment Scale – Level of Risk (Combination of Likelihood and Impact)

Likelihood (That Occurrence Results in Adverse Impact)	Level of Impact				
	Very Low	Low	Moderate	High	Very High
Very High	Very Low	Low	Moderate	High	Very High
High	Very Low	Low	Moderate	High	Very High
Moderate	Very Low	Low	Moderate	Moderate	High
Low	Very Low	Low	Low	Low	Moderate
Very Low	Very Low	Very Low	Very Low	Low	Low

Risk Assessment Approach

Determine relevant threats to the IS. List the risks to the IS in the Risk Assessment Results table below and detail the relevant mitigating factors and controls. Refer to NIST SP 800-30 for further guidance, examples, and suggestions.

Risk Assessment Results

Threat Event	Vulnerabilities / Predisposing Characteristics	Mitigating Factors	Likelihood (Tbl 2 or 3)	Impact (Table 4)	Risk (Tbls 5 & 6)
Unauthorized Network Reconnaissance	No firewall or perimeter filtering, private IP subnets exposed due to the absence of NAT	VLAN segmentation limits network visibility access and WPA2-PSK security limits wireless access	High	Low	Low

Threat Event	Vulnerabilities / Predisposing Characteristics	Mitigating Factors	Likelihood (Tbl 2 or 3)	Impact (Table 4)	Risk (TbIs 5 & 6)
Unauthorized Access	No firewall or port filtering present at network perimeter. The absence of NAT configuration makes private subnets easily accessible.	VLAN segmentation limits horizontal movement. WPA2-PSK requires a password to access wireless networks.	High	Moderate	Moderate
Denial of Service (DoS) Attacks	The lack of port filtering and rate limiting allows for unlimited access to the network. The absence of NAT configuration exposes private targets.	VLAN segmentation limits the blast radius of affected systems.	Moderate	High	Moderate
Establishment of Command and Control (C2) Chains	No egress filtering or traffic monitoring; outbound connections to external infrastructure are unrestricted and undetected.	VLAN segmentation limits C2 reach to compromised segment only; unclassified data limits sensitivity of potential exfiltration.	Moderate	Moderate	Moderate

* Likelihood / Impact / Risk = Very High, High, Moderate, Low, or Very Low

Controls Implemented

SC-7 (Boundary Protection)

Extended ACLs are configured on the WAN interface of each institution's router, filtering all inbound and outbound traffic at the network perimeter. BLOCK_INBOUND denies unsolicited inbound connections. Tech Company topology additionally implements a Cisco ASA 5506-X firewall between the DMZ and internal employee network.

SC-7(5) (Deny by Default)

All ACLs terminate with an explicit `deny ip any any` rule, enforcing deny-by-default on all perimeter interfaces across all five institutions.

SC-7(8) (Controlled Managed Interface)

All traffic passes through router perimeter interfaces with ACLs enforced. Tech Company implements a dedicated DMZ architecture with VLAN segmentation where the ASA acts as a controlled boundary between internal and public-facing resources.

SC-5 (Denial of Service Protection)

ALLOW_OUTBOUND ACLs restrict outbound traffic to ports 80, 443, 53, and ICMP only, reducing the attack surface for DoS vectors. NAT/PAT hides internal targets from direct exposure. This architecture ensures the functionality of the topology by permitting access to only the necessary protocols (ICMP, HTTP, HTTPS, and DNS).

SI-4 (4)(Inbound and Outbound Communications Traffic)

ALLOW_OUTBOUND and BLOCK_INBOUND ACLs on each institution's router only permit communication between only the necessary services to access the web server and its website, HTTP, HTTPS, and DNS on ports 80, 443, and 53 respectively. ICMP is also enabled on the public facing interface for troubleshooting. Every other protocol and port is denied entry and exit.

Note that Cisco Packet Tracer does not fully support inbound and outbound monitoring. So, SI-4(4) cannot be fully implemented, and in an enterprise environment, stateful monitoring with a stateful firewall, an NGFW, or an IDS/IPS would need to be implemented to satisfy this standard.

NAT/PAT

PAT is configured on all five institution routers translating private subnets to a single public IP, hiding internal network topology from external threat actors. Static NAT is configured on Tech Company server for public-facing web and DNS server.

DMZ Architecture (Tech Company)

Web and DNS server isolated in a dedicated DMZ subnet (192.168.42.0/24). ACLs enforce external access to DMZ on ports 80/443/53 for HTTP/HTTPS/DNS only. Internal access to DMZ is permitted, and DMZ-initiated connections to the internal network are blocked.